



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Normativa de Ciberseguridad

TEMA 1

UT01.- Puntos principales sobre el cumplimiento normativo

Alberto Diéguez Álvarez

Apartado 1: Cumplimiento y Normativa	3
1.- La nueva Ley 2/2023 obliga a las empresas a implementar un canal de denuncias. Considerando que Innovatech tiene 150 empleados, ¿qué obligaciones específicas tiene al respecto? ¿Podría compartir recursos con otras empresas para gestionar este canal?	3
2.- Innovatech busca la certificación ISO 27001:2022. Menciona y describe brevemente dos de los nuevos controles introducidos en esta versión que serían especialmente importantes para una empresa como Innovatech y su modelo de negocio (p. ej., seguridad en la nube, inteligencia de amenazas).	4
Apartado 2: Buen Gobierno y Ética Empresarial	5
3.- La dirección de Innovatech se prepara para una futura salida a bolsa, lo que implica un mayor escrutinio por parte de inversores y reguladores. Desde la perspectiva del buen gobierno corporativo, ¿qué responsabilidades específicas debería asumir el Consejo de Administración en materia de ciberseguridad y supervisión del uso ético de la IA? Describe al menos dos responsabilidades para cada área (ciberseguridad y ética en IA).	5
4.- El uso de Inteligencia Artificial conlleva nuevos dilemas éticos. Propón cinco principios o normas que incluirías en el código ético de Innovatech, centrados específicamente en el desarrollo ético de la IA y la protección de la privacidad de los datos que sus sistemas procesan.	6
Apartado 3: Relaciones con Terceras Partes	6
5.- Toda la operación de Innovatech depende de su proveedor de servicios en la nube. Describe qué elementos clave analizarías en un proceso de diligencia debida para asegurar que este proveedor externo cumple con los requisitos de seguridad y normativos que Innovatech necesita para protegerse a sí misma y a sus clientes.	6

¿Qué te pedimos que hagas?

Innovatech Solutions es una empresa tecnológica española en plena expansión, con una plantilla de 150 empleados. Se especializa en el desarrollo de software a medida que utiliza inteligencia artificial (IA) para optimizar la cadena de suministro de empresas de logística. Su software gestiona datos críticos de sus clientes, como rutas de transporte, inventarios y datos de destinatarios finales.

La empresa tiene una cartera de clientes nacionales e internacionales, incluyendo una importante compañía farmacéutica de Estados Unidos, lo que les obliga a ser extremadamente cuidadosos con la privacidad y la seguridad de los datos que manejan.

Recientemente, Innovatech ha sufrido una fuga de datos menor que fue contenida a tiempo, pero que ha encendido las alarmas en la dirección. Como resultado, la empresa se ha puesto como objetivo prioritario obtener la certificación ISO 27001 en su nueva versión de 2022 para reforzar la confianza de sus clientes. Además, para financiar su expansión, la dirección está preparando a la empresa para una futura salida a bolsa.

Todo el desarrollo y la infraestructura de Innovatech opera sobre servicios de un conocido proveedor de computación en la nube (Cloud). La dirección, consciente de los nuevos retos legales y éticos, quiere asegurarse de que la empresa no solo cumple con la normativa, sino que también opera bajo los más altos estándares de buen gobierno y ética empresarial.

Teniendo en cuenta la compañía descrita en el escenario anterior, da respuesta a las siguientes preguntas:

Apartado 1: Cumplimiento y Normativa

1.- La nueva Ley 2/2023 obliga a las empresas a implementar un canal de denuncias. Considerando que Innovatech tiene 150 empleados, ¿qué obligaciones específicas tiene al respecto? ¿Podría compartir recursos con otras empresas para gestionar este canal?

Otras obligaciones que se deberían implementar son:

- Un código ético, es decir un conjunto de principios y pautas de conducta.
- Un conjunto de buenas prácticas.
- Identificación de compromisos a dividir en: legales, normativos, contractuales y organizacionales.
- Actividades de formación para concienciar a la organización sobre los deberes y obligaciones.
- Sistema de gestión de cumplimiento, para mejorar el proceso de cumplimiento.

Otras obligaciones especificadas en la ley [2/2023](#)

- El órgano de administración u órgano de gobierno será el responsable de la implantación del Sistema interno de información.
- Permitir a todas las personas comunicar la infracción.
- Debe estar establecido de forma segura, de forma que se garantice la confidencialidad del informante y de cualquier tercero.
- Permitir la presentación de comunicación por escrito, verbalmente o de ambos modos.
- Contar con un responsable del sistema.
- Garantizar que las comunicaciones puedan tratarse de manera efectiva dentro de la entidad.
- Establecer garantías para la protección de los informantes.

Para responder a la pregunta de si puede compartir recursos, nos basamos en el siguiente artículo de la ley 2/2023:

Artículo 12 del Capítulo II del Título II de la ley 2/2023:

Artículo 12. Medios compartidos en el sector privado.

Las personas jurídicas en el sector privado que tengan entre cincuenta y doscientos cuarenta y nueve trabajadores y que así lo decidan, podrán compartir entre sí el Sistema interno de información y los recursos destinados a la gestión y tramitación de las comunicaciones, tanto si la gestión se lleva a cabo por cualquiera de ellas como si se ha externalizado, respetándose en todo caso las garantías previstas en esta ley.

Las empresas de 50 a 250 trabajadores pueden compartir medios y recursos. Pueden externalizar el canal a un tercero, compartir una plataforma común o compartir personal para la gestión, esto se cumpliría siempre que cada empresa tenga su canal propio y diferenciado y que cada una mantenga su propio responsable de sistema y control sobre el proceso.

2.- Innovatech busca la certificación ISO 27001:2022. Menciona y describe brevemente dos de los nuevos controles introducidos en esta versión que serían especialmente importantes para una empresa como Innovatech y su modelo de negocio (p. ej., seguridad en la nube, inteligencia de amenazas).

Buscando información sobre la certificación (añado una pequeña webgrafía):

- https://es.wikipedia.org/wiki/ISO/IEC_27001
- <https://www.iso.org/es/norma/27001>
- <https://www.nqa.com/medialibraries/NQA/NQA-Media-Library/PDFs/Spanish%20QRFs%20and%20PDFs/NQA-ISO-27001-Guia-de-implantacion.pdf>
- <https://www.piranirisk.com/es/blog/cambios-norma-iso-27001-2022>
- <https://www.tuvnord.es/todo-sobre-la-nueva-version-iso-27001-2022/>

Se nombran dos controles introducidos en esta versión y que son especialmente importantes para la empresa y su modelo de negocio:

Nuevos controles: Se han añadido nuevos controles para abordar temas actuales como la seguridad en la nube, la inteligencia artificial y las amenazas cibernéticas.

- Seguridad en servicios Cloud: Definir responsabilidades entre Innovatech y el proveedor Cloud. Asegurar que la configuración, acceso, almacenamiento ... se realice de forma segura.
- Amenazas cibernéticas: Recopilar, analizar y usar la información. Integrarla en la respuesta a los incidentes.

Apartado 2: Buen Gobierno y Ética Empresarial

3.- La dirección de Innovatech se prepara para una futura salida a bolsa, lo que implica un mayor escrutinio por parte de inversores y reguladores. Desde la perspectiva del buen gobierno corporativo, ¿qué responsabilidades específicas debería asumir el Consejo de Administración en materia de ciberseguridad y supervisión del uso ético de la IA? Describe al menos dos responsabilidades para cada área (ciberseguridad y ética en IA).

Ciberseguridad:

- **Supervisión del entorno de control de la organización:**
 - Definir equipos de supervisión de control interno, auditorías internas, reportando directamente al comité de dirección.
 - Formación de los consejeros en políticas de control internos y gestión de riesgos.

Éticas en IA:

- **Estructura organizativa de la empresa:**
 - Definición de roles y responsabilidades para cada función. Para mejorar el uso y la responsabilidad de la IA.
- **Sistemas de gestión del cambio:**
 - Existencia de procesos de monitorización de factores externos (legislación, competencia, mercado, economía, geopolítica) y análisis de los impactos en el negocio para establecimiento de procesos de innovación. Con estos procesos se mejoraría el análisis del impacto del negocio.

4.- El uso de Inteligencia Artificial conlleva nuevos dilemas éticos. Propón cinco principios o normas que incluirías en el código ético de Innovatech, centrados específicamente en el desarrollo ético de la IA y la protección de la privacidad de los datos que sus sistemas procesan.

- **Principios y valores de responsabilidad y rendición de cuentas:** Al poner en el centro la responsabilidad y las consecuencias aplicando cultura, valores y principios para la organización, se conseguiría un mejor uso de IA en gestión de datos.
- **Existencia de un código de conducta:** Informar sobre cómo la IA actúa, que datos usa y con qué finalidad para garantizar el buen uso de la misma.
- **Políticas de gestión de riesgos:** Solo se podrá usar la IA con los datos justos y necesarios.
- **Existencia de consejeros externos:** Con el fin de garantizar el respeto a la privacidad, ausencia de conflictos de interés... El uso de la IA se revisará periódicamente por agentes externos.
- **Establecimiento de programas formativos:** Cualquier persona que participe en algún proyecto de la empresa y utilice IA, deberá recibir formación para uso ético.

Apartado 3: Relaciones con Terceras Partes

5.- Toda la operación de Innovatech depende de su proveedor de servicios en la nube. Describe qué elementos clave analizarías en un proceso de diligencia debida para asegurar que este proveedor externo cumple con los requisitos de seguridad y normativos que Innovatech necesita para protegerse a sí misma y a sus clientes.

Para asegurar que el proveedor de servicios cumple con los requisitos de seguridad, a esta se le exigiría el **cumplimiento normativo** y ciertas certificaciones. Por ejemplo, como se comentó anteriormente, **ISO 27001** sería un buen punto a tener en cuenta, también tener auditorías externas y controles por parte de terceros.

Analizaría también la **gestión de incidentes** y la respuesta de esta. Tomando nota de los tiempos de respuesta y que procedimientos utilizan.

Algo muy importante hoy en día sería revisar minuciosamente como se gestiona la **protección de datos y privacidad**, tener garantías del cumplimiento de GDPR (Reglamento General de Protección de Datos), tener consciencia de los datos que se almacenan, como se almacenan, con qué finalidad y asegurar en todo momento la privacidad y el uso ético de los datos.

Cierta **transparencia** por parte del proveedor, comprobando la existencia de controles internos, auditorías internas, cultura ética y una supervisión de sus propios controles.